

1. Identificacion del contrato

Proposito	Mercado simple de NFTs: un vendedor lista un precio y un comprador paga para adquirir el id.
Actores	Vendedor (list), Comprador (buy).
Flujo de fondos	buy() reenvia msg.value directamente al seller global.

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	seller y price globales sobrescribibles por cualquiera Root: Estado de listado global y compartido en lugar de por token; sin verificacion de propiedad.	list() fija variables globales seller y price sin verificar propiedad del NFT ni asociarlas a un id. Cualquiera puede sobrescribirlas en cualquier momento. Vector: Front-running: el atacante llama list() justo antes del buy() de la victima para convertirse en seller y cobrar el pago, o cambia price.	High	SWC-114	SC01:2026 Access Control
2	Compra sin custodia real del activo Root: Modelo de propiedad/escrow ausente.	No hay NFT en custodia; buy() solo escribe ownerOf[id]=msg.sender y paga al seller. No valida que el id exista o pertenezca al seller. El parametro id de list() ni se usa. Vector: Pago por un activo inexistente; intercambio no atomico.	Medium	N/A	SC02:2026 Business Logic Errors
3	Falta validacion de precio Root: Sin require(price>0).	price puede ser 0; require(msg.value >= price) sin mensaje y sin minimo. Vector: Compras a precio 0 o estados degenerados.	Low	N/A	SC05:2026 Lack of Input Validation

3. Analisis de logica de negocio

El listado compartido permite secuestrar la venta; comprador y vendedor no tienen garantias atomicas de intercambio.
--

6. Benchmark metrics

3 Total	0 Critical	1 High	1 Medium	1 Low	0.88 Confidence	0.85 Precision	1.00 Coverage	45 Time (s)	60 Risk
------------	---------------	-----------	-------------	----------	--------------------	-------------------	------------------	----------------	------------

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).